RESUMEN

Módulo 5: Análisis de Alertas y Eventos

- ✓ Una alerta es una señal, no una conclusión. El analista valida, no acepta ciegamente.
- ✓ Evento ≠ Alerta ≠ Incidente. La distinción define cómo responder.
- ✓ La severidad de la herramienta es el punto de partida. La severidad real se construye con contexto.
- ✓ El proceso padre y la línea de comandos son la evidencia más importante en alertas de endpoint.
- ✓ Login exitoso con MFA no descarta compromiso. La actividad posterior define el riesgo.
- ✓ Una consulta DNS ≠ conexión exitosa. Una conexión bloqueada ≠ caso cerrado.
- ✓ La correlación une fuentes para construir una hipótesis. Endpoint + correo + red + identidad = historia completa.
- ✓ Validar no es justificar el cierre. Requiere revisar evidencia concreta: ticket, alcance, actividad posterior.
- ✓ Cerrar, monitorear, validar y escalar son las cuatro decisiones posibles. Cada una requiere justificación.
- ✓ La incertidumbre se documenta, no se inventa. El lenguaje debe reflejar el nivel de evidencia disponible.

El objetivo: que el alumno no solo lea alertas, sino que piense como analista.

⚠️ Errores comunes del Analista SOC — Módulo 5

✘ Cerrar porque la alerta fue bloqueada

✔️ Un bloqueo reduce el riesgo inmediato pero no revisa si hay actividad previa, otros hosts o persistencia.

✘ Usar solo la severidad de la herramienta

✔️ Severity:Low puede ser crítico (regla de correo del CFO). Severity:High puede ser actividad autorizada.

✘ No revisar el parent process ni la línea de comandos

✔️ Son los campos más importantes para interpretar alertas de proceso/LOLBin.

✘ Cerrar porque el MFA fue exitoso

✔️ MFA no descarta compromisos por phishing AiTM, fatigue, token robado o sesión secuestrada.

✘ Ignorar la actividad posterior al login o a la ejecución

✔️ El 'después' es muchas veces lo que define si hay incidente.

✘ Usar lenguaje absoluto sin evidencia

✔️ Escribir 'Falso positivo' o 'Es C2' sin justificación pierde credibilidad y puede ocultar incidentes.

✘ No documentar limitaciones de visibilidad

✔️ 'No pasó nada' ≠ 'No encontré evidencia en las fuentes disponibles'. Son frases muy distintas.

✘ Escalar sin explicar la secuencia

✔️ L2 no debería tener que reconstruir el análisis desde cero. Un buen escalamiento resume qué se observó.



HIDDEN SECURITY

Modern SOC Operations — Módulo 5